Aula 1 – Introdução a Cybersecurity

Prof. Henrique Batista da Silva

Contato e acesso ao material

- Nome
  - Henrique Batista da Silva

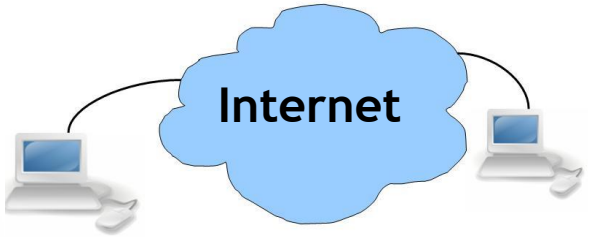
Na aula de hoje

- Introdução aos conceitos de Segurança da Informação e aplicações
- Principais vulnerabilidades
- Principais formas de ataques.

Introdução

Segurança da Informação

- A Internet se tornou essencial para muitas instituições hoje. Empresas grandes, pequenas, Universidades e órgãos do governo. Além de pessoas que usam a Internet para atividades profissionais e pessoais.



Segurança da Informação

- Segurança em redes de computadores abrange **como "vilões" podem ameaçar as redes de computadores** e **como nós podemos nos defender**.

Vulnerabilidades

- Falhas de projeto/implementação/configuração de um software que pode ser explorada com intuito de violar a segurança do computador.

Principais origens das vulnerabilidades

- Deficiência de projeto: brechas no hardware/software
- Deficiência de implementação: instalação/configuração incorreta, por inexperiência, falta de treinamento ou desleixo
- Deficiência de gerenciamento: procedimentos inadequados, verificações e monitoramentos insuficientes

Principais origens das Vulnerabilidades

- Exemplos:
  - Instalação física: má proteção física de equipamentos e mídia
  - Hardware e Software: situações não previstas, limites, bugs no projeto, deixando brechas que podem ser exploradas
  - Mídia: roubo, perda, danificação, desgaste de discos, fitas etc.
  - Transmissão: interceptação de sinal, monitoramento, grampo
  - Humana: desleixo, preguiça, ignorância, ganância, revolta, etc.

Principais origens das Vulnerabilidades

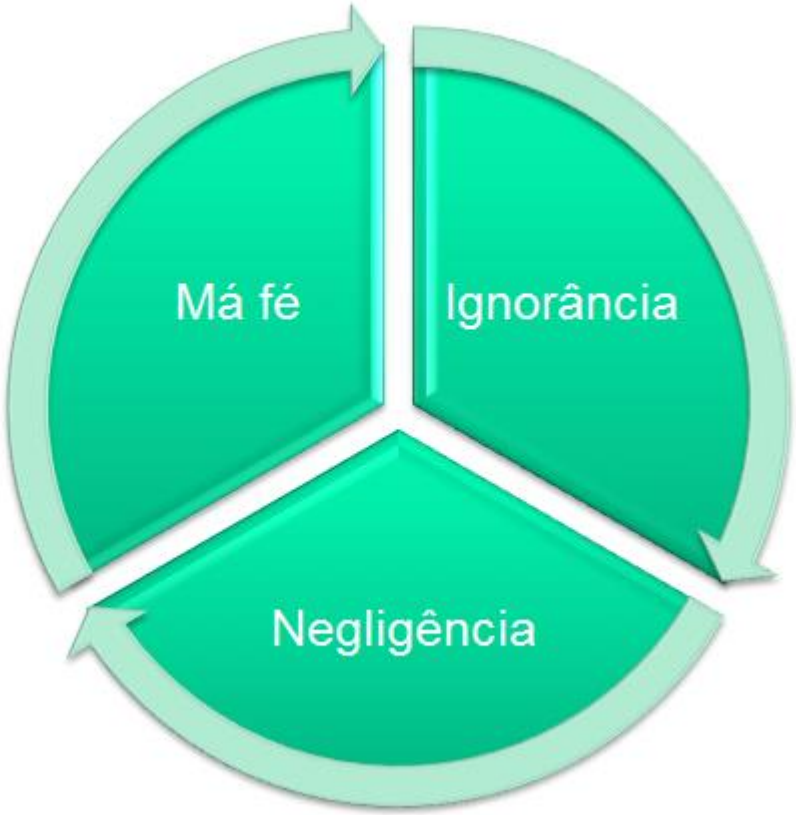
BRASÍLIA

Incêndio no prédio do INSS queima processos de sonegadores

27/12/2005 | 11h48 | O Globo/Globo Online | Atualizado em 27/12/2005 às 11h48

Um incêndio destruiu, na manhã desta terça-feira, seis dos dez andares do prédio da Previdência Social, em Brasília. O ministro da Previdência e Assistência Social, Nélson Machado, revelou que o incêndio destruiu os processos relativos aos devedores do INSS. Os documentos estavam no setor de recursos humanos do órgão e na Secretaria da Receita Previdenciária.

Pessoas



Pessoas

Documentos confidenciais da polícia são descartados no meio de avenida movimentada em SP

SÃO PAULO - Documentos confidenciais da polícia são encontrados no meio de avenida movimentada em São Paulo. A reportagem do SPTV encontrou à beira da Avenida Vinte e Três de Maio, uma das mais movimentadas de São Paulo, um monte de papéis produzidos por uma delegacia de polícia, próximo de onde os papéis foram descartados. Tratam-se de boletins de ocorrência, fichas de identificação, dados criminais, pedidos de perícia, todos documentos confidenciais e emitidos neste ano.

Pessoas

30 Jan

Empregada irada apaga todos os dados da empresa

Por Redação em Notícias. Visualizado 82852 vezes desde **30 de janeiro de 2008** às 08:36:40

Marie Lupe Cooley, 41 anos de idade, de Jacksonville na Flórida, leu um anúncio de emprego no jornal local onde aparecia o número telefônico de seu chefe, e tudo indicava que era o seu próprio cargo que estava sendo ofertado.

Apesar da interpretação não ser correta,ou seja, não era o cargo dela que estava sendo ofertado, Marie Lupe nem pensou duas vezes, cheia de ira dirigiu-se ao escritório de arquitetura onde trabalhava, procurando vingança. Cooley apagou todos os dados dos sistemas da empresa, incluindo os "backups". Assim, sete anos de trabalho foram deletados, incluindo projetos detalhados com valor estimado de 2,5 milhões de dólares.

- *"Decidiu-se a prejudicar todo mundo. Sabotou toda a empresa achando que seria despedida"*, comentou o sheriff Ken Jefferson a Fox News.

Fora o gerente da empresa, Cooley era a única pessoa que tinha pleno acesso aos arquivos apagados. Portanto, rapidamente ficou evidente quem tinha apagado o material.

Cooley foi denunciada por vandalismo grave. Os arquivos foram resgatados mediante uso de software de recuperação de dados que permite, inclusive, buscar arquivos deletados.

Cooley, agora sim, foi despedida por justa causa.

Engenharia Social

"É a ciência que estuda como o conhecimento do comportamento humano pode ser utilizado para **induzir uma pessoa** a atuar segundo seu desejo. Não se trata de hipnose ou controle da mente, as técnicas de Engenharia Social são amplamente utilizadas por detetives (para obter informação) e magistrados (para comprovar se um declarante fala a verdade). Também é **utilizada para lograr todo tipo de fraudes**, inclusive invasão de sistemas eletrônicos."

Engenharia Social

Engenharia Social

- Porque as pessoas são vulneráveis a manipulações?
  - Ambição
  - Vaidade
  - Carência afetiva
  - Curiosidade
  - Etc

Engenharia Social

03/04/2011 22h51 - Atualizado em 03/04/2011 22h51

Falso coronel revela como enganou a polícia do Rio e chegou a secretaria

Carlos da Cruz Sampaio Júnior chegou a ser coordenador de subsecretaria. Em entrevista exclusiva, ele conta que nunca cursou academia militar.

"Eu consegui porque entrei e ninguém me perguntou nada e nem pediu nenhuma identificação...".

Segurança da Informação

- A Internet é insegura, mas foi criada para ser assim, um local ondem **pessoas de confiança podem se comunicar**.
- Os usuários atuais ainda precisam se comunicar, mas não é mais um meio de segurança mútua.
- Há muitos desafios relacionados a segurança.

Segurança da Informação

22/06/2011 19h19 - Atualizado em 22/06/2011 19h33

Ataque hacker foi o maior já sofrido por sites do governo na internet

Servidores na Itália teriam sido ponto de partida para ação de grupo. LulzSecBrazil reivindicou autoria de ataque de 'negação de serviço'.

O ataque hacker às páginas da Presidência da República, Portal Brasil e da Receita na madrugada desta quarta-feira (22) foi o maior já sofrido pela rede de computadores do governo brasileiro. De acordo com o Serviço Federal de Processamento de Dados (Serpro), o ataque - que não causou danos às informações disponíveis nas páginas - partiu de servidores localizados na Itália.

Segurança de Sistemas de Informação

Segurança da Informação

PUC Minas

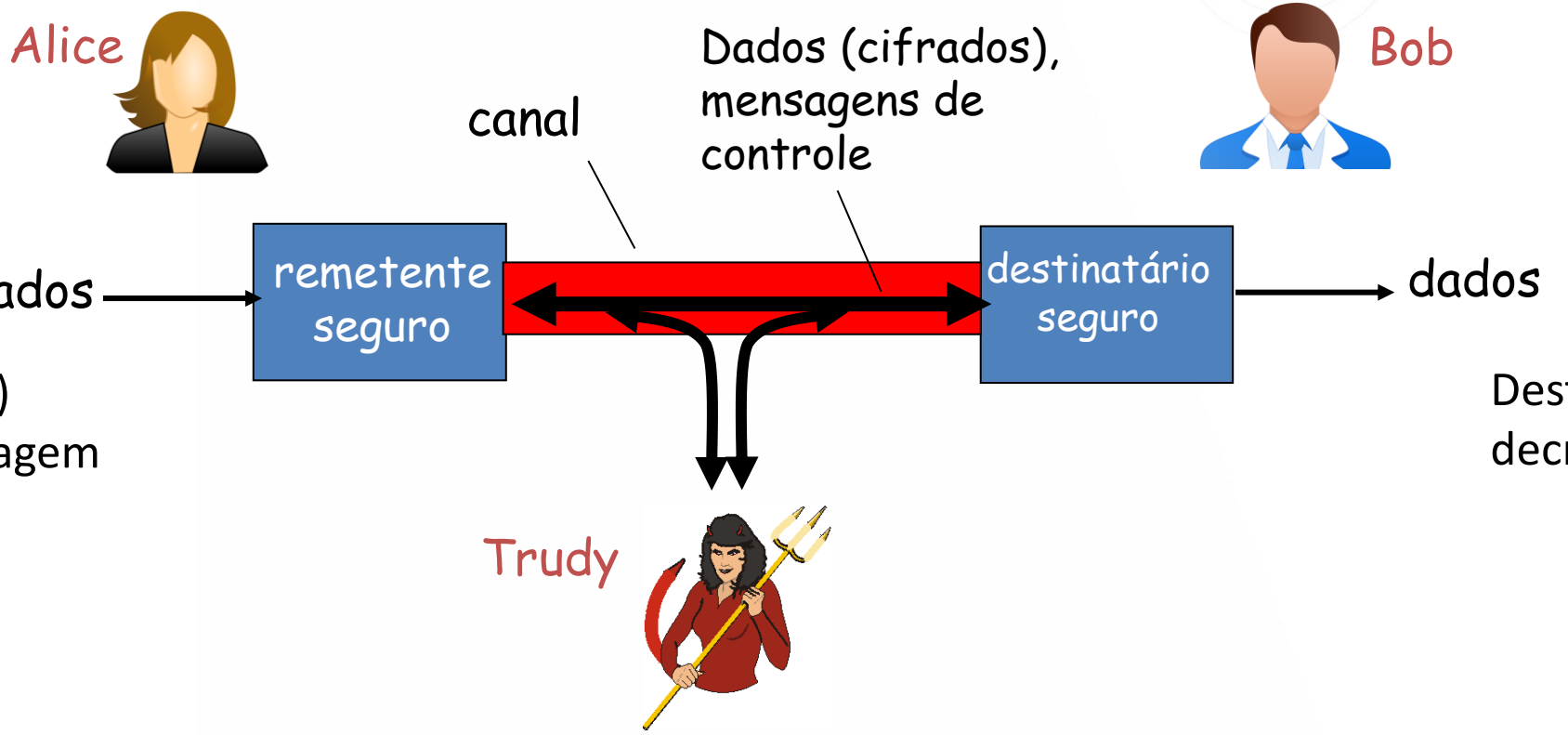
Segurança da Informação

É uma característica da informação que diz respeito ao **direito de acesso**.

Garantir que a informação esteja **acessível apenas para quem tem permissão de acesso**, evitando, assim, revelação não autorizada

Confidencialidade

Apenas remetente e destinatário pretendido devem "entender" conteúdo da mensagem



Remetente (Alice) criptografa mensagem

Destinatário (Bob) decripta mensagem

Segurança da Informação

É uma característica da informação que diz respeito à sua **exatidão**

Garantir que a informação **seja alterada somente por pessoas autorizadas** e em **situações** que efetivamente demande uma alteração **legítima**

acessível apenas para quem tem permissão de acesso

PUC Minas

Integridade

28/02/2012 16h50 - Atualizado em 28/02/2012 17h58

'Carta de amor' vai parar no Diário da Justiça do Trabalho da Paraíba

Carta foi publicada no lugar do resultado de um processo.
Justiça informou que servidora responsável já foi exonerada.

24/01/2014 12h40 - Atualizado em 24/01/2014 12h40

TRF condena a União por 'Carta de amor' em Diário Oficial na Paraíba

TRF da 5ª Região manteve indenização de R$ 20 mil por danos morais.
Professora de educação física se sentiu ofendida com carta publicada.

Segurança da Informação

alterada somente por pessoas autorizadas

acessível apenas para quem tem permissão de acesso

Garantir que a informação esteja **disponível**, **sempre que necessário**, aos usuários **que tenham direito** de acesso a ela.

PUC Minas

Segurança da Informação

alterada somente por pessoas autorizadas

acessível apenas para quem tem permissão de acesso

informação disponível sempre que necessário

Garantir que a informação provém da fonte anunciada e que não foi alvo de mutação ao longo de sua transmissão.

PUC Minas

Segurança da Informação

alterada somente por pessoas autorizadas

acessível apenas para quem tem permissão de acesso

Ou irretratabilidade, garantia de que o **autor** de determinada ação **não possa negar** tal ação.

informação disponível sempre que necessário

garantir meios que identifique inequivocamente o autor de uma ação.

certeza da origem da informação.

PUC Minas

Segurança da Informação

alterada somente por pessoas autorizadas

acessível apenas para quem tem permissão de acesso

autor de determinada ação **não possa negar** tal ação.

informação disponível sempre que necessário

certeza da origem da informação.

PUC Minas

Segurança na Tecnologia da Informação

- Negócios dependentes cada vez mais dos sistemas de informação e da Internet
- Problemas:
  - Infecção por vírus,
  - Acesso não autorizado,

Segurança na Tecnologia da Informação

- Problemas (cont.):
  - Ataques *denial of service* contra redes e sistemas,
  - Furto de informação proprietária,
  - Invasão de sistemas, fraudes internas e externas,
  - Espionagem sobre as redes,
  - Entre outras.

Ambiente de trabalho

- Atacantes Internos
  - Possuem autorização legítima para acesso e uso de informação, sistema, rede.
  - Fazem mau uso dos privilégios que possuem Legitimamente.
  - Tentam obter de maneira ilícita acessos com mais poderes.
  - Motivações: vingança ((ex)funcionário insatisfeito), ganho financeiro (fraude, roubo de informação privilegiada), desafio.

Ambiente de trabalho

- Problemática dos ambientes de TI
  - Ambientes mais complexos e heterogêneos
  - Diversos fornecedores
  - Necessidade de pessoal com formações especializadas
  - Complexidade na administração dos ambientes
  - Muita demanda de serviços via TI e urgências

Ambiente de trabalho

- Problemas mais comuns:
  - Uso dos recursos de Tecnologia da Informação (TI) da organização para interesses pessoais
  - Uso malicioso ou negligente dos recursos de Tecnologia da Informação (TI) da organização

Aspectos Legais

- Responsabilidade Civil dos Executivos, Gestores e Profissionais em geral
  - Executivos, gestores e profissionais de TI respondem legalmente pelos danos causados através dos meios eletrônicos.

Aspectos Legais

- O Código Civil prevê que o empregador é responsável por tudo o que os trabalhadores fazem usando as conexões e os equipamentos da empresa

*Isso significa que, se um funcionário cometer um crime por meio do computador do trabalho, **a empresa responde judicialmente pelo caso**.*

O funcionário também poderá responder pelo crime, mas os prejudicados costumam processar as empresas por conta de elas terem mais poder e dinheiro em caso de indenizações.

Principais Ameaças e Vulnerabilidades

Malware

- Código malicioso
- Termo que abrange todos os tipos de programa especificamente desenvolvidos para executar ações maliciosas em um computador.

Malware

- Malwares podem infectar computadores através da Internet.
  - São auto reprodutivos: infecta um hospedeiro e, a partir dele, infecta outros.
  - Malware do tipo spyware: podem registrar toques de teclas, sites visitados, etc.

Malware

- Podem se espalhar na forma de vírus, worms ou cavalo de Tróia.
  - Vírus são malwares que necessitam de uma interação com o usuário para infectar o aparelho (ex: anexo de e-mail com código malicioso).
  - Worms: podem entrar em um aparelho sem qualquer interação com o usuário. Exploração automática de vulnerabilidades em programas.
  - Cavalo de Tróia: parte oculta de um software funcional.

Vírus

- Programa ou parte de um programa de computador, normalmente malicioso, que se propaga inserindo cópias de si mesmo e se tornando parte de outros programas e arquivos.
- Depende da execução do programa/arquivo hospedeiro.

Vírus

- Principais meios de propagação: e-mail e pen-drive
- Tipos mais comuns de vírus:
  - vírus propagado por e-mail
  - vírus de script
  - vírus de macro
  - vírus de telefone celular

Cavalo de troia/trojan

- Programa que, além de executar as funções para as quais foi projetado, também executa outras funções, normalmente maliciosas, e sem o conhecimento do usuário
- Necessita ser explicitamente executado para ser instalado

wikimedia.org

Ransomware

- Programa que torna inacessíveis os dados armazenados em um equipamento, geralmente usando criptografia, e que exige pagamento de resgate para restabelecer o acesso ao usuário

Ransomware

- Costuma buscar outros dispositivos conectados, locais ou em rede, e criptografá-los também
- Pagamento do resgate (ransom) geralmente feito via bitcoins
- Reforça a importância de ter backups
  - mesmo pagando o resgate não há garantias de que o acesso será restabelecido

Ransomware

- Ameaça recente: Ransoware (sequestro de dados por criptografia)

Pontos de infecção do ataque de maio/2017

Bot

- Programa que dispõe de mecanismos de comunicação com o invasor que permitem que ele seja controlado remotamente.
- Um computador infectado por um bot costuma ser chamado de **zumbi**, pois pode ser controlado remotamente, sem o conhecimento do seu dono

Botnet

- Rede formada por centenas ou milhares de zumbis, que permite potencializar as ações danosas dos bots
- O controlador da botnet pode:
  - usá-la para seus próprios ataques
  - alugá-la para outras pessoas ou grupos que desejem
  - executar ações maliciosas específicas

Spyware

- Programa para monitorar as atividades de um sistema e enviar as informações coletadas para o atacante
- Exemplos:
  - Keylogger: captura e armazenar as teclas digitadas pelo usuário no teclado do computador

Spyware

- Screenlogger: armazena a posição do cursor e a tela apresentada no monitor, no momento de um clique do mouse.
- Adware: criado para apresentar propagandas

Rootkit

- Software/Código malicioso que esconde a si mesmo dentro de outros programas (legítimos) do computador sem que o usuário (e até antivírus) perceba sua presença.
- Podem capturar informações sobre o computador/rede, ser usado para ataque DDoS e minerar bitcoins.

Backdoor

- Programa que permite o monitoramento a distância (por meio de um serviço) de um computador alvo de ataque.
- Possibilita que o invasor veja (ou apague) seus arquivos, senhas, número de cartões de crédito, etc..

Worm

- Se propaga automaticamente pela rede, por envio de cópias de si mesmo.
- Consomem recursos devido á grande quantidade de cópias geradas.
- Afeta o desempenho das redes e dos computadores.

Principais ataques

DoS – Denial of Service

- Recusa de serviço (DoS – Denial of Service): atacantes deixam recursos (servidor, largura de banda) indisponíveis ao tráfego legítimo (por meio de sobrecarga).

DoS – Denial of Service

- São ataques extremamente comuns na Internet.
  - (1) Selecionar alvo (algum servidor)
  - (2) Invadir hospedeiros na rede
  - (3) Enviar pacotes para o alvo a partir dos hospedeiros comprometidos (desktops, celulares ou qualquer dispositivo conectado).

DoS - Denial of Service

- Os DoS podem ser divididos em três categorias:
  - Ataque de vulnerabilidade: envio de mensagens a uma aplicação vulnerável, onde o hospedeiro pode parar de funcionar.

DoS - Denial of Service

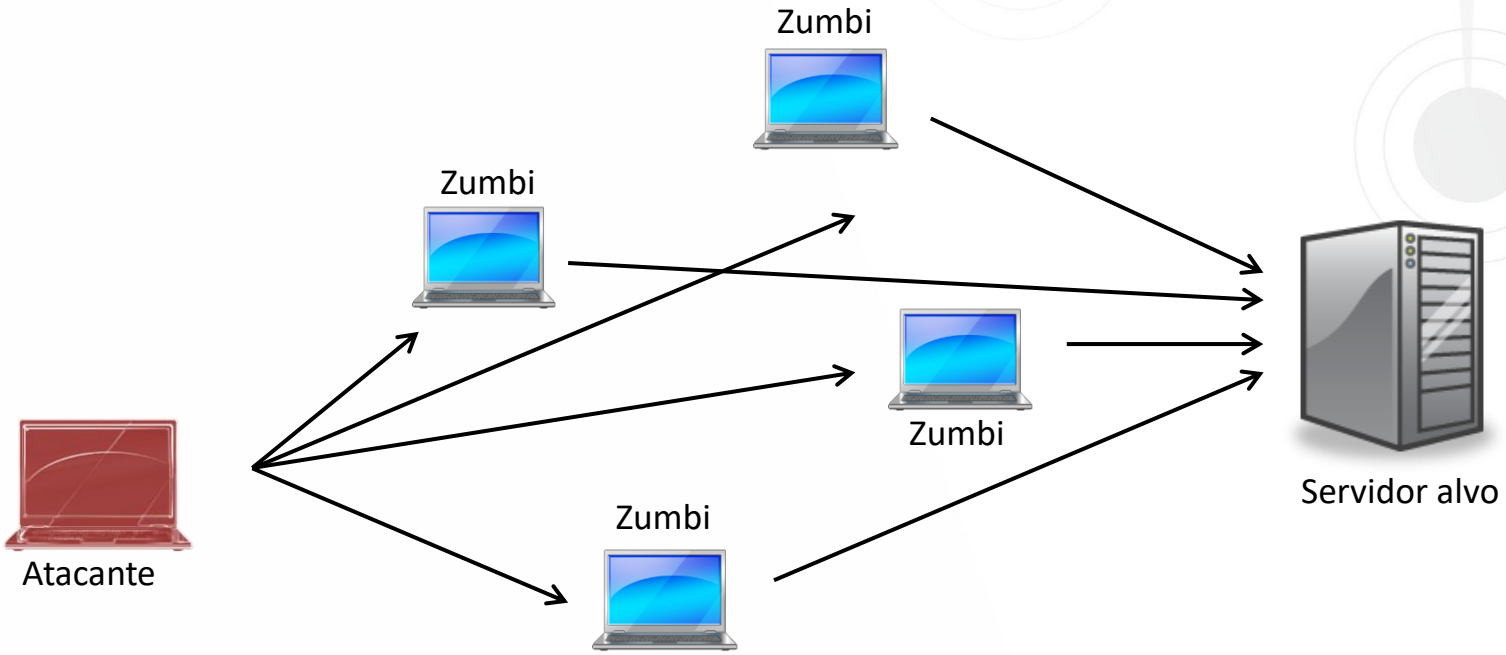
- Inundação na largura de banda: o atacante envia uma grande número de pacotes ao hospedeiro, congestionando o enlace
- Inundação na conexão: Atacante estabelece uma grande número de conexão TCP abertas no alvo.

DDoS – Distributed Denial of Service

- Em um ataque DoS distribuído (DDoS), o ataque controla múltiplas fontes que sobrecarregam o alvo.
- Potencializam botnets com centenas de hospedeiros comprometidos (comum hoje em dia).
- Mais difíceis de detectar e prevenir do que o DoS

DDoS - Distributed Denial of Service

- Exemplo de um ataque DDoS.



DDoS – Distributed Denial of Service

- É crescente o problema com o aumento de dispositivos conectados (câmeras de segurança, impressoras, celulares, etc)
- Tema muito relevante com o advento da IoT.

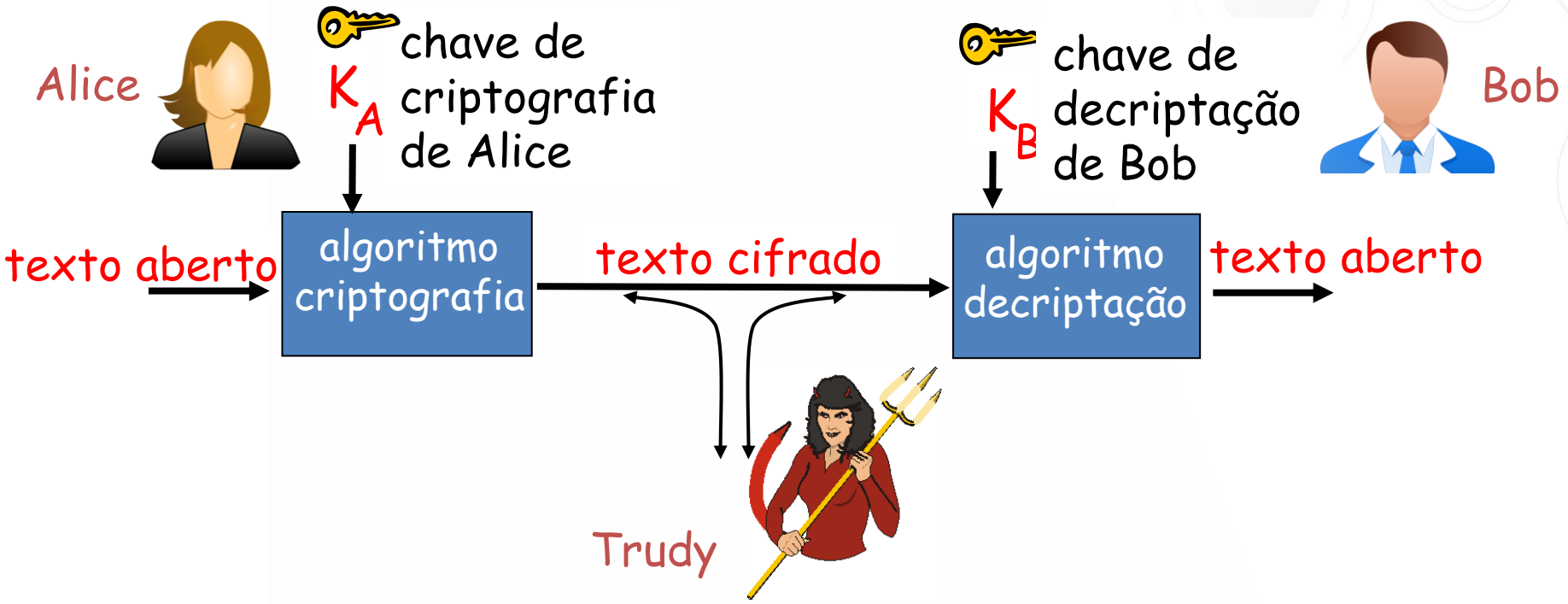
Análise de pacotes (Sniffing)

- A conexão sem fio se tornou comum.
- Problema de segurança: a presença de um receptor passivo lendo pacotes.
- Analisador de pacotes: receptor passivo que copia e passa os pacotes (ocorre com transmissão a cabo também).

Análise de pacotes (Sniffing)

- Analisador de pacotes são passivos, ou seja, não enviam pacotes e, por isso, são difíceis de detectar.
- Criptografia: um meio de evitar que as informações sejam lidas por analisadores passivos

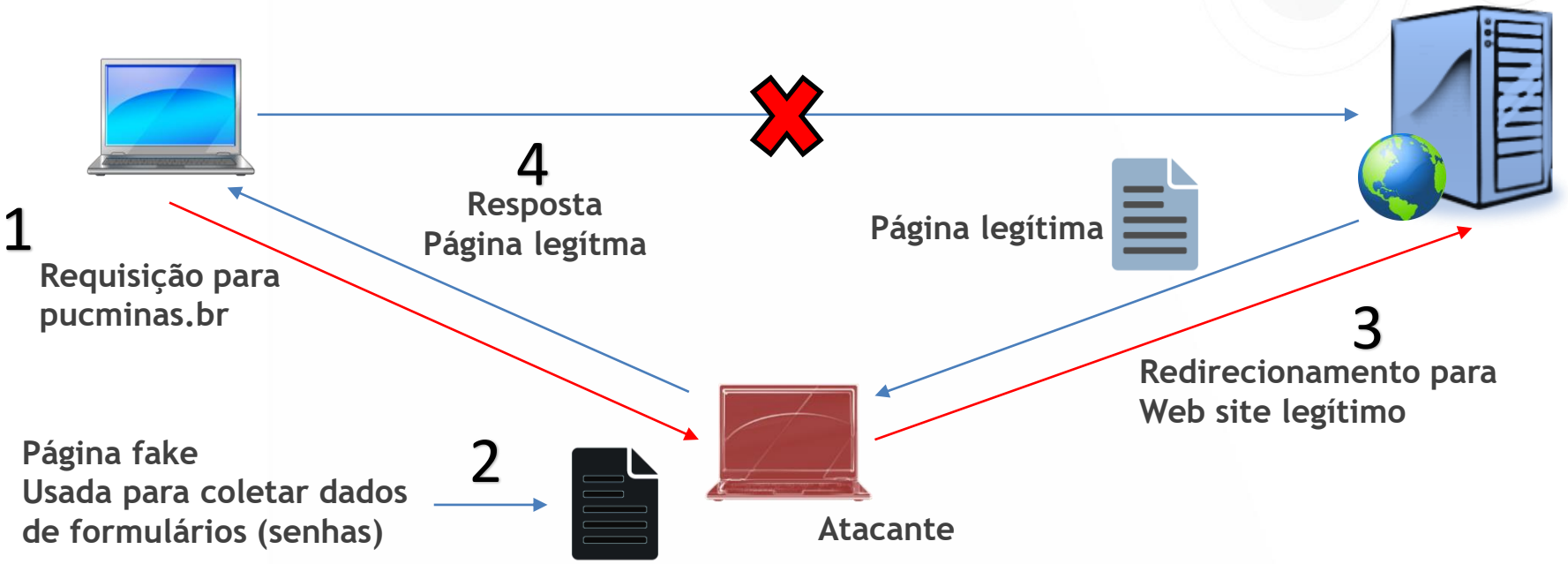
Análise de pacotes (Sniffing)



Man in the middle

- O vilão é infiltrado no percurso da comunicação entre duas entidades comunicantes.
- Neste tipo de ataque, o vilão não só pode analisar todos os pacotes como também pode alterar e excluir mensagens.

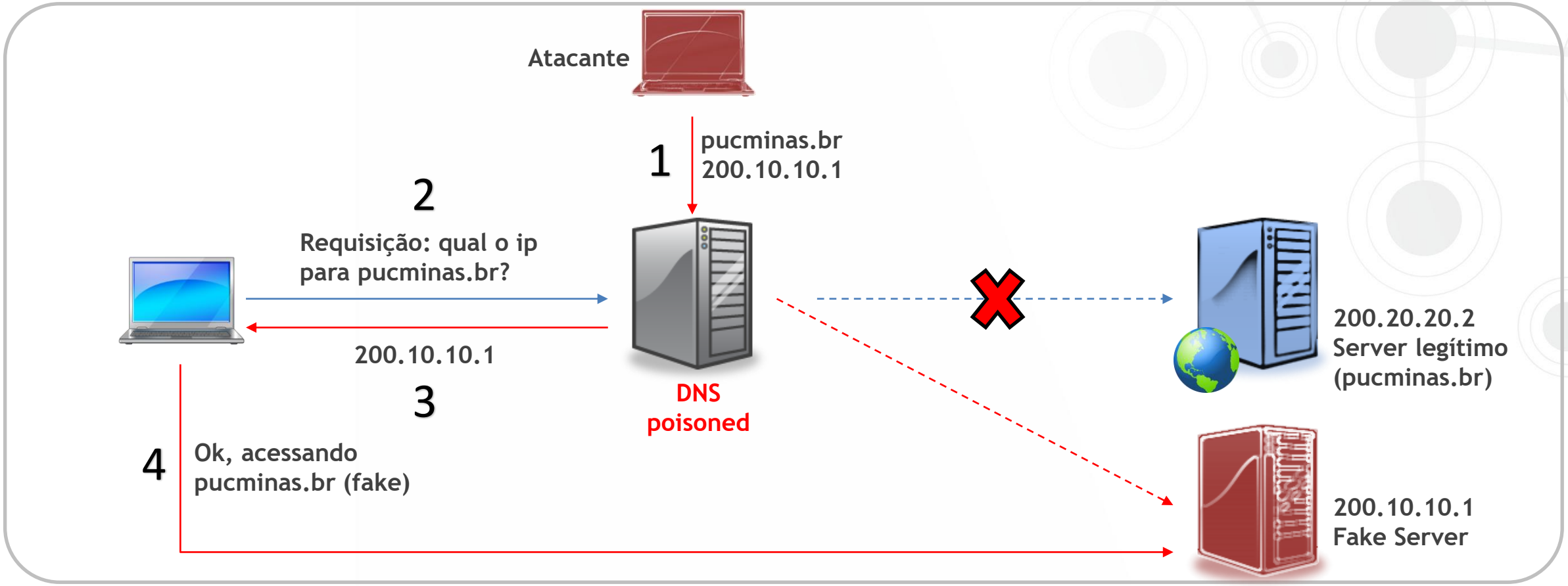
Man in the middle (um exemplo)



DNS Cache Poisoning

- Um ataque pode alterar o real endereço ip de um servidor (Web site) em um cache DNS.
- A vítima será então induzida a acessar um endereço fake.

DNS Cache Poisoning



DNS Cache Poisoning

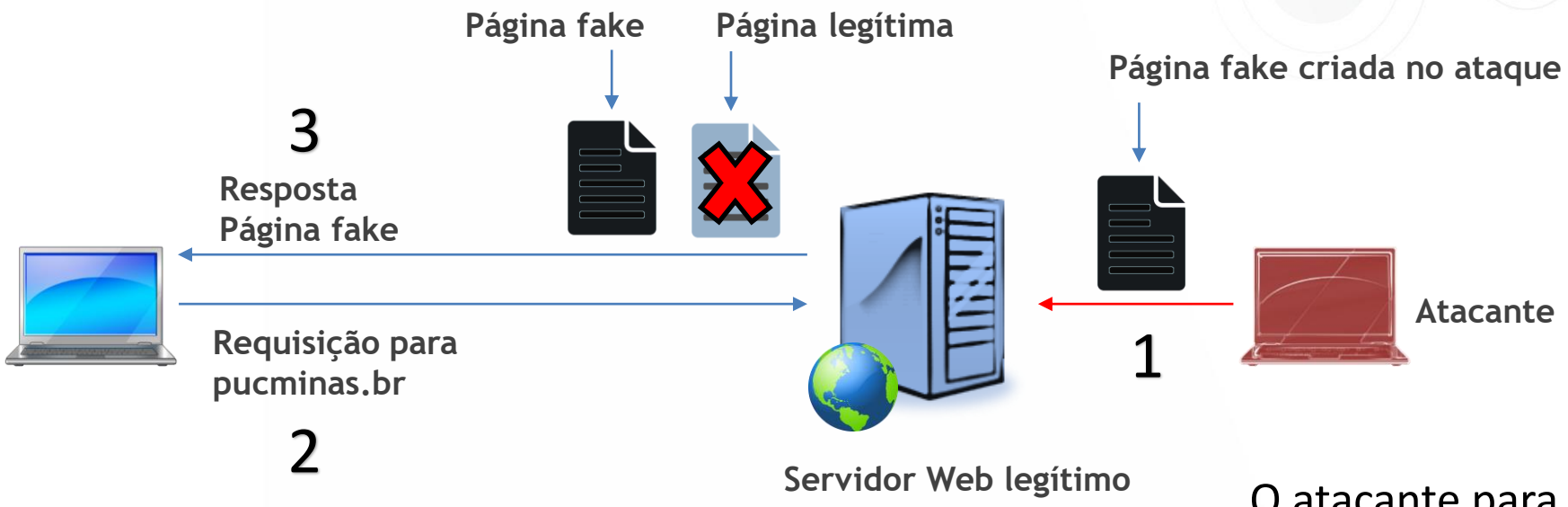
- Ataque sofrido por servidores DNS no Brasil (jan/2017) que redirecionava a página do google para um servidor fake.

Imagem de um servidor fake (jan/2017)

Defacement

- Um ataque altera o conteúdo de uma página Web, deixando o conteúdo real indisponível.

Defacement



O atacante para explorar vulnerabilidades no servidor Web ou até erros na aplicação Web

Brute Force

- Um ataque de força bruta, ou brute force, consiste em adivinhar, por tentativa e erro, um nome de usuário e senha para acesso indevido à Web sites, servidores, etc..
- Utiliza-se de ***wordlists*** para proferir o ataque (lista de palavras mais comuns para senhas).

Engenharia Social

- Método de ataque que faz uso da persuasão, se aproveitando da ingenuidade do indivíduo (confiança) para obtenção de informações que deveriam ser confidenciais ou de acesso restrito.

Engenharia Social - Exemplos

- Ligação de desconhecido que diz ser do suporte técnico do provedor de Internet. Ele diz que a conexão está apresentando algum problema e pede a senha do cliente para corrigi-lo.
- Mensagem de e-mail dizendo que o seu banco necessita de algumas informações.
- Etc..

Phishing

- Roubo de identidade online. Envio de mensagem não autorizada se passando por alguma instituição conhecida para tentar induzir o acesso da vítima para roubo de informações (dados pessoais, cartões de crédito, etc.).

Phishing

- Principais situações envolvendo phishing:
  - mensagens que contêm links para programas maliciosos;
  - páginas de comércio eletrônico ou Internet Banking falsificadas;
  - e-mails contendo formulários para o fornecimento de informações sensíveis;
  - comprometimento do serviço de resolução de nomes (DNS).

Spam

- E-mails não solicitados que são, normalmente, enviados para um grande número de pessoas.
- Serviços de e-mails oferecem soluções razoáveis para filtro deste tipo de e-mail.
- Problemas como: Perda de mensagens importantes, conteúdo impróprio, gasto desnecessário de tempo e de banda, etc..

Outros riscos

- Cookies: arquivos gravados em seu computador quando acessa algum site. Ele contém informações sobre como carrinho de compras, lista de produtos e preferências de navegação.
- Riscos: Compartilhamento de informações, Coleta de informações pessoais e hábitos de navegação.

Outros riscos

- Janelas de pop-up: aparecem automaticamente e sem permissão, sobrepondo a janela do navegador.
- Riscos: apresenta links que podem redirecionar para páginas falsas ou executar scripts maliciosos.

Outros riscos

- Plug-ins, complementos e extensões: programas desenvolvidos por terceiros (em sua maioria) para o navegador Web que provê funcionalidades extras.
- Riscos: tais programas podem executar atividades maliciosas ou que, devido a vulnerabilidades, deixar o computador exposto a um ataque.

Outros riscos

- Programas de distribuição de arquivos (P2P): permitem que usuários compartilhem arquivos entre si diretamente (sem uso de servidor). Alguns exemplos: Kazaa, Emule e BitTorrent.
- Riscos: Acesso indevido, obtenção de arquivos maliciosos, violação de direitos autorais.

Hackers famosos

- Robert Tappan Morris.

Em 1988, enquanto estudante da Universidade de Cornell, Morris libertou o primeiro "worm" que infectou e danificou 6000 computadores com Unix (10% da Internet da época). Hoje é professor do MIT.

Hackers famosos

- Kevin Poulsen.

Em 1990, atacou a linha telefônica de uma rádio norte americana e com isso garantiu que seria a 102ª pessoa a ligar e ganhar um Porsche. Hoje é editor da revista Wired.

Hackers famosos

- Kevin Poulsen.

Em 1990, atacou a linha telefônica de uma rádio norte americana e com isso garantiu que seria a 102ª pessoa a ligar e ganhar um Porsche. Hoje é editor da revista Wired.

Hackers famosos

- Kevin David Mitnick.
- Popularizou o termo Engenharia Social

Começou na adolescência invadindo o computador da escola para alterar suas notas. Famoso por invasões principalmente operadoras de telefonia nos anos 90. Preso em 1995 e solto em 2000. Hoje é consultas de Segurança.

Referências

- KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006.
- TANENBAUM, Andrew S. Redes de Computadores. 5ª Edição: Campus, 2003
- CHESWICK, William R.; BELLOVIN, Steven M.; RUBIN, Aviel D. Firewalls e Segurança na Internet. 2 ed. Porto Alegre: Bookman, 2005